UNIT 5 · TOPIC 5.6

Application Threat Auditing

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. Which of the following BEST describes the purpose of a file integrity monitoring (FIM) system?

○ A. A firewall rule set that prevents unauthorized write access to protected directories

● B. A tool that detects changes to files by comparing their current cryptographic hashes against a recorded baseline

○ C. An antivirus scanner that removes malware found inside system files

○ D. A backup utility that creates periodic snapshots of critical data directories

Correct answer: B

Why: FIM computes cryptographic hashes (e.g., SHA-256) of monitored files and stores them as a known-good baseline. On each scan cycle it recomputes hashes and alerts when any value differs from the baseline, revealing unauthorized modifications to data or configuration files, a core data-attack detection strategy.

*Why the others are wrong: **A**, Conflates FIM with access-control enforcement; a firewall or ACL prevents writes but does not detect changes that bypass those controls. **C**, Conflates detection with remediation; antivirus removes malware but does not specifically monitor file integrity against a baseline. **D**, Conflates FIM with backup/recovery; backups preserve data but do not alert on unauthorized modification events.*

2. A security analyst downloads a software package from a vendor's website. Before installation, the analyst wants to verify the package has not been tampered with during transit. Which action BEST achieves this?

● A. Compare the SHA-256 hash of the downloaded package against the hash published on the vendor's official site

○ B. Run the installer inside a sandboxed virtual machine before deploying to production

○ C. Verify that the file extension matches the expected package type

○ D. Scan the package with a network-based intrusion detection system prior to installation

Correct answer: A

Why: Hash verification works because a cryptographic hash function produces a unique fixed-length digest for a given input. Any modification to the file, even a single bit, changes the digest. Comparing the computed hash to the vendor's published value confirms the file's integrity. If hashes match, the file is unaltered.

*Why the others are wrong: **B**, Sandboxing is a useful isolation technique but does not verify the file's integrity against a known-good state; a tampered installer still executes inside the sandbox. **C**, File extensions are metadata only; an attacker can replace a legitimate binary with a malicious one while preserving the extension, making this check trivially bypassable. **D**, NIDS analyzes network traffic, not the content of a file already downloaded to disk; it cannot verify a file's integrity against a published hash.*

3. Which type of log is MOST directly useful for detecting unauthorized access attempts against a web application?

○ A. System boot log

○ B. DHCP lease log

● C. Web server access log

○ D. Hardware event log

Correct answer: C

Why: Web server access logs record each HTTP request including source IP address, HTTP method, requested URI, and response status code. This data directly surfaces patterns characteristic of application attacks (e.g., repeated 4xx errors, directory traversal strings in URIs, abnormally rapid request sequences from a single IP).

*Why the others are wrong: **A**, Boot logs record OS startup events and are useful for detecting unauthorized reboots or kernel modifications, not application-level access attempts. **B**, DHCP logs map IP addresses to MAC addresses and lease times; useful for network inventory but not for detecting application attack attempts. **D**, Hardware event logs record physical device faults (disk errors, memory failures); they contain no information about application traffic.*

4. An organization wants to detect SQL injection attempts against its customer portal in real time. Which control is MOST appropriate?

- **● A. Deploying a web application firewall (WAF) configured with SQL injection detection signatures**
- ○ B. Encrypting the database at rest using AES-256
- ○ C. Enforcing multi-factor authentication for all database administrators
- ○ D. Applying role-based access control to database tables

Correct answer: A

Why: A WAF with SQL injection signatures inspects incoming HTTP request payloads in real time, matching content against known injection patterns before the request reaches the application. This provides real-time detection (and optionally blocking) at the network boundary, the most direct control for this detection requirement, aligned with NIST SP 800-44 application security guidance.

*Why the others are wrong: **B**, Encryption at rest protects data confidentiality if storage media is stolen; it does nothing to detect active injection attempts against the running application. **C**, MFA limits who can log in to administer the database but does not analyze or detect malformed query patterns originating from the application layer. **D**, RBAC is a preventive control restricting what an authenticated principal can access; it does not detect attack attempts from unauthenticated or externally-facing attack traffic.*

5. A financial institution must detect when sensitive data files are being exfiltrated through its internal network. Which detection control BEST addresses this requirement?

- ○ A. An endpoint encryption agent that automatically encrypts all outbound files
- ○ B. A backup system that archives all files to an offline location daily
- ○ C. A network firewall rule blocking all outbound traffic on port 443
- **● D. A data loss prevention (DLP) system configured with policies for sensitive data patterns such as account numbers and PII**

Correct answer: D

Why: DLP systems inspect outbound network traffic and file transfer operations for content matching sensitive data policies (e.g., regular expressions for account numbers, SSNs). When a match is found, the system generates an alert and optionally blocks the transfer, directly addressing the real-time exfiltration detection requirement.

*Why the others are wrong: **A**, Encryption protects data confidentiality in transit but does not detect or prevent exfiltration; an attacker can exfiltrate encrypted data just as easily as plaintext. **B**, Offline backups are a recovery control; they preserve data but provide no real-time visibility into exfiltration events. **C**, Blocking port 443 indiscriminately would break all HTTPS traffic including legitimate business operations, operationally impractical and not a targeted detection control.*

6. Which combination of controls provides the MOST comprehensive detection coverage for attacks against an application's data layer?

- **● A. Database activity monitoring (DAM) and file integrity monitoring (FIM)**
- ○ B. Antivirus software and a host-based firewall
- ○ C. Role-based access control and full-disk encryption
- ○ D. VPN tunneling and multi-factor authentication

Correct answer: A

Why: DAM continuously records and analyzes all database queries, detecting anomalous access patterns, unauthorized privilege escalation, and suspicious SELECT or DROP operations at the data-access tier. FIM simultaneously monitors the integrity of data files on disk, detecting unauthorized modification or replacement. Together they provide complementary detection across both the logical (query) and physical (file) dimensions of the data layer.

*Why the others are wrong: **B**, Antivirus and host-based firewalls target malware execution and inbound network connections; they are not tuned to detect data-layer attacks such as abnormal query patterns or file tampering. **C**, RBAC and encryption are preventive controls; they limit access and protect confidentiality but do not generate detection alerts when attacks occur. **D**, VPN and MFA are access security controls that verify identity before granting entry; they do not monitor what an authenticated (or compromised) session does to data afterward.*

7. A CISO is evaluating whether to deploy network-based intrusion detection (NIDS) or host-based intrusion detection (HIDS) to detect attacks against application data. Which assessment BEST captures the operational trade-off between the two approaches in a TLS-encrypted environment?

○ A. NIDS is always preferable because it requires no agents on endpoints and provides perimeter-wide coverage.

● B. HIDS provides granular visibility into file and process activity on individual hosts; NIDS cannot inspect application-layer content after TLS termination occurs inside the host.

○ C. HIDS should always be chosen because network traffic inspection violates user privacy law in most jurisdictions.

○ D. NIDS and HIDS are functionally identical for this use case; the choice is purely one of deployment convenience.

Correct answer: B

Why: Once a TLS session is terminated at the application server, the decrypted payload is invisible to a NIDS positioned on the network segment, the NIDS sees only encrypted bytes. A HIDS operates on the host after decryption, with access to actual file system operations, process activity, system calls, and local log entries. For detecting data-layer attacks (e.g., a process reading unauthorized files, a query tool exfiltrating a database dump to disk), HIDS provides the necessary post-decryption visibility that NIDS cannot.

*Why the others are wrong: **A**, NIDS perimeter coverage is real but its limitation in encrypted environments is a critical blind spot for application-layer detection, overstating its superiority ignores this well-documented constraint. **C**, This frames a purely technical limitation as a legal one, conflating network monitoring (which organizations typically conduct under acceptable-use policy) with privacy law; it is not the primary reason to choose HIDS. **D**, NIDS and HIDS differ fundamentally in what they can observe; the TLS visibility gap makes them non-equivalent for application data-layer detection.*

8. An organization deploys file integrity monitoring but configures it to alert on ALL file changes, including OS patch installations, application log rotation, and temporary cache writes. Which consequence is MOST likely to undermine the detection strategy?

○ A. The FIM system will be unable to compute valid hashes for files that have been updated by the patch manager.

● B. Security analysts will experience alert fatigue, reducing the probability that genuine tampering events receive timely investigation.

○ C. Application log files will be automatically excluded from FIM coverage by the operating system.

○ D. The organization will automatically satisfy NIST SP 800-53 continuous monitoring requirements.

Correct answer: B

Why: When FIM is misconfigured to fire on every routine system change, it produces excessive false-positive alerts that outnumber genuine tampering events by orders of magnitude. Alert fatigue causes analysts to deprioritize or dismiss alerts without investigation, creating an operational window during which actual unauthorized file modifications go undetected. Effective FIM requires a curated exclusion list for known-good change events (patch windows, log rotation schedules) so that remaining alerts represent high-confidence anomalies.

*Why the others are wrong: **A**, FIM continues to compute hashes normally for updated files; the system still functions technically. The problem is not hash computation failure but analyst response failure. **C**, Operating systems do not automatically exclude log files from third-party monitoring tools; exclusions must be explicitly configured by the administrator. **D**, Alert volume has no bearing on compliance status; NIST 800-53 CA-7 requires a continuous monitoring strategy, generating excessive noise while missing real events is contrary to this requirement, not compliant with it.*

9. A security architect is comparing two detection strategies for application attacks: signature-based detection and anomaly-based detection. Which evaluation MOST accurately characterizes the inherent trade-offs of each approach?

○ A. Signature-based detection is superior because well-maintained rule sets produce zero false positives by definition.

○ B. Anomaly-based detection is always preferable because signatures become outdated the moment a new attack variant is released.

○ C. Both methods produce identical detection rates and false positive rates because they process the same underlying log data.

● D. Signature-based detection reliably identifies known attack patterns with low false positives but fails against novel or obfuscated techniques; anomaly-based detection can surface unknown attacks but generates elevated false positives during initial baseline establishment.

Correct answer: D

Why: This accurately captures the complementary strengths and weaknesses documented in NIST SP 800-94 (Guide to IDS/IPS). Signature-based systems excel at precision for catalogued threats, low false positives, high false negatives for zero-days. Anomaly-based systems sacrifice early-deployment precision (elevated false positives while learning normal behavior) for the capability to detect novel attacks that have no signature. Security architectures that layer both approaches gain broader coverage than either alone.

*Why the others are wrong: **A**, Signature-based systems produce false positives when legitimate traffic matches a rule pattern, a documented operational reality; "zero false positives" is not a property of any deployed detection technology. **B**, Signatures for well-characterized attack classes (e.g., SQL injection syntax, known CVE exploit payloads) remain accurate and valuable across many years; "immediately outdated" overstates the limitation. **C**, Detection approach fundamentally determines what gets flagged, same log data analyzed by different algorithms produces materially different alert sets. The two are not equivalent.*

10. A security analyst computes the SHA-256 hash of a critical system configuration file and records the value as a baseline. One week later, the analyst recomputes the hash of the same file and finds the value has changed. What does this indicate?

○ A. The SHA-256 algorithm has weakened over time, producing inconsistent outputs for identical input.

● B. The configuration file's contents have been modified since the baseline was recorded.

○ C. The file system automatically compressed the file to recover disk space, altering the stored bytes.

○ D. The analyst selected a different hash algorithm for the second computation, producing a different output length.

Correct answer: B

Why: Cryptographic hash functions are deterministic, identical input always produces identical output. A differing hash value for the same file means the file's contents have changed between measurements, regardless of whether the change was made by an authorized administrator, an attacker, or an automated process. This is the fundamental basis of integrity verification.

*Why the others are wrong: **A**, Hash algorithms do not degrade over time in normal operation; SHA-256 always produces the same 256-bit output for the same input. "Weakening" refers to cryptanalytic attacks, not output inconsistency. **C**, Transparent filesystem compression would change the stored representation but the hash should still reflect the logical file content; more importantly, compression events are logged and predictable, not the expected cause of an unexplained hash mismatch. **D**, The stem states the analyst recomputed the hash, implying the same process, and the question is about what a changed value indicates, not about algorithm differences; this distractor targets students who confuse algorithm selection with determinism.*

11. Which of the following entries in a web application access log is MOST likely an indicator of a directory traversal attack?

○ A. GET /images/logo.png HTTP/1.1 200

○ B. POST /api/login HTTP/1.1 401

● C. GET /../../etc/passwd HTTP/1.1 403

○ D. GET /index.html HTTP/1.1 304

Correct answer: C

Why: The `../../` sequence in the URI is a classic directory traversal pattern. The attacker attempts to navigate above the web root using relative path components to access `/etc/passwd`, a sensitive OS file outside the intended application directory. The 403 response indicates the server rejected the request, but the attempt itself is an indicator of attack that must be logged and investigated.

*Why the others are wrong: **A**, A 200 response for a static image asset is a normal, expected log entry with no indicators of malicious intent. **B**, A 401 on a login endpoint indicates a failed authentication attempt, suspicious in high volume but structurally different from a directory traversal indicator. **D**, A 304 Not Modified response to a conditional GET for a static page is entirely benign browser caching behavior.*

12. A SOC receives an alert stating that an executable on a production web server has a SHA-256 hash that does not match the value published by the software vendor. Which classification BEST describes this finding?

● A. An indicator of compromise (IoC) suggesting the file may have been replaced or backdoored

○ B. A false positive caused by antivirus software quarantining part of the file

○ C. An expected result of operating system localization adapting the binary for the regional environment

○ D. A routine outcome when software is updated through an automated patch management system

Correct answer: A

Why: A hash mismatch between a production executable and its vendor-published digest is a textbook indicator of compromise. The file may have been replaced by a weaponized version, injected with a backdoor, or corrupted by an attacker. Until proven otherwise through investigation, it must be treated as a compromise, the SOC should quarantine the host and escalate.

*Why the others are wrong: **B**, Antivirus quarantine typically moves or deletes a file rather than modifying it; even if quarantine were the cause, the correct response is to investigate, not to immediately dismiss as a false positive. **C**, OS localization does not modify compiled executable binaries; locale settings affect text display, not binary content. **D**, Legitimate patches do change hashes, but a well-managed patch process updates the FIM baseline at the time of patching. An unexplained hash mismatch with no corresponding authorized change record remains an IoC.*

13. An analyst reviews the following Apache access log entries:

192.168.10.44 - - [04/Jul/2026:14:22:01] "GET /admin/config.php HTTP/1.1" 200 4821
192.168.10.44 - - [04/Jul/2026:14:22:03] "GET /admin/users.php HTTP/1.1" 200 9342
192.168.10.44 - - [04/Jul/2026:14:22:05] "POST /admin/users.php HTTP/1.1" 200 512
192.168.10.44 - - [04/Jul/2026:14:22:08] "GET /admin/backup.php HTTP/1.1" 200 1284

Which attack behavior do these log entries MOST likely indicate?

○ A. A brute-force credential stuffing attack targeting the admin login page

○ B. A legitimate administrator performing routine site maintenance tasks

● C. An attacker systematically enumerating and interacting with administrative pages after gaining unauthorized access

○ D. A denial-of-service attack consuming server resources through repeated HTTP requests

Correct answer: C

Why: Four distinct administrative endpoints are accessed sequentially from a single IP in under 10 seconds, all returning HTTP 200 (successful). The POST to users.php with a small response body (512 bytes) suggests a data-modification action (e.g., adding a user or changing a password). The rapid, systematic traversal of config, user management, and backup endpoints is consistent with an attacker who has already authenticated and is performing post-compromise reconnaissance and manipulation of the admin interface.

*Why the others are wrong: **A**, Credential stuffing targets authentication endpoints (e.g., /login) with repeated attempts and typically produces many 401 or 403 responses, not sequential 200s across diverse admin pages. **B**, Legitimate administrator activity is possible but unlikely given the sub-10-second span across four functionally distinct administrative areas; human administrators do not navigate four separate admin tools in 7 seconds. **D**, A DoS attack would generate far higher request volume targeting the same endpoint to exhaust resources, not four methodical requests to four different admin pages.*

14. A log analysis platform flags 4,000 failed database queries from the application server within 30 seconds. Each flagged query contains the SQL fragment `UNION SELECT`. Which attack class is MOST consistent with this pattern?

○ A. A cross-site scripting (XSS) attack injecting malicious scripts through the database

● B. A UNION-based SQL injection attack attempting to extract data by appending attacker-controlled SELECT statements

○ C. A denial-of-service attack aimed at exhausting the database connection pool through query flooding

○ D. A brute-force attack cycling through common database user passwords

Correct answer: B

Why: UNION SELECT is a specific SQL injection technique where an attacker appends a second SELECT statement to a legitimate query using the UNION operator, extracting data from other tables in the same response. The high query volume in a compressed time window is characteristic of automated injection tooling (e.g., sqlmap) cycling through column-count probes and data-type compatibility tests to build a successful UNION payload.

*Why the others are wrong: **A**, XSS is a client-side attack; payloads are injected into HTML responses served to browsers, not into SQL database queries. XSS does not produce UNION SELECT patterns in database logs. **C**, DoS attacks against a database connection pool generate high-volume connection requests or long-running queries, not syntactically structured UNION SELECT statements. **D**, Password brute-force attacks operate at the authentication layer using credential inputs, not SQL syntax in the query layer.*

15. Application event logs show that a service account named `svc_backup`, normally active only between 02:00 and 04:00 UTC, is generating authentication events continuously from 11:00 to 23:00, accessing files outside its usual backup directories. Which detection technique BEST classifies this behavior?

● A. Behavioral anomaly analysis comparing observed account activity against its established baseline

○ B. Signature-based detection using a known malware hash database

○ C. Port scanning to enumerate which services the account is communicating with externally

○ D. Vulnerability scanning of the backup server to identify exploitable weaknesses

Correct answer: A

Why: The account's activity deviates substantially from its documented behavioral baseline on two dimensions: time (wrong activity window) and scope (unauthorized file paths). Behavioral anomaly analysis detects this class of threat, compromised service accounts and lateral movement, by comparing current activity to historical norms rather than matching against known-bad signatures. This technique is especially effective for detecting attacks that use legitimate credentials, which leave no malware artifacts for hash-based detection to find.

*Why the others are wrong: **B**, Hash-based signature detection requires a file artifact to hash and compare; this scenario presents only account behavior in logs, with no file artifact yet identified. Signatures cannot flag an account acting outside its normal time window. **C**, Port scanning maps network topology and open services from outside a host; it does not analyze internal account activity patterns already captured in application logs. **D**, Vulnerability scanning identifies unpatched weaknesses in software; it does not analyze active account behavior or alert on behavioral anomalies in log data.*

16. A SOC is evaluating two detection approaches: (1) a traditional SIEM with manually authored correlation rules, and (2) an AI-powered behavioral analytics platform that models normal application traffic to surface anomalies. A senior analyst asks which system is expected to produce a higher false positive rate during the first 30 days of deployment. Which response BEST reflects the documented trade-off?

○ A. Both systems will have identical false positive rates because they analyze the same underlying log stream.

○ B. The traditional SIEM, because manually authored correlation rules are known to generate more alerts than AI systems in every deployment scenario.

● C. The AI platform, because it requires a learning period to establish baselines and will initially flag many legitimate behaviors as anomalous.

○ D. Neither system will produce false positives; false positives only arise in antivirus systems and are not a property of SIEM or AI analytics platforms.

Correct answer: C

Why: AI behavioral analytics platforms require a baseline learning period, typically two to four weeks, during which normal traffic patterns are not yet well-modeled. Rare-but-legitimate behaviors (end-of-quarter batch jobs, one-time data migrations) that fall outside the early baseline will trigger anomaly alerts. Manually authored SIEM rules, while imprecise, reflect intentional analyst judgment and domain knowledge from day one. As the AI model matures, its false positive rate typically decreases below that of static rule sets, but the first 30 days favor the SIEM on precision.

*Why the others are wrong: **A**, The detection approach fundamentally determines which events are flagged; identical log data analyzed by a rules engine versus an ML model produces different alert populations. **B**, Overgeneralizes, SIEM rule quality varies enormously; a well-tuned SIEM can be more precise than an untuned AI model early in deployment, but claiming SIEM is always worse in all scenarios is not evidenced. **D**, False positives occur in all detection technologies including SIEM and AI analytics; this claim is factually incorrect.*

17. A forensic analyst investigating an incident finds the following evidence: (1) web application logs showing repeated HTTP 500 errors triggered by requests containing a single-quote character; (2) a database audit log recording queries with `OR '1'='1'` appended to WHERE clauses; (3) a timestamped export file of the full users table created during the incident window. Which conclusion BEST integrates all three evidence streams?

○ A. The server experienced a routine database connectivity failure unrelated to external input.

○ B. An XSS attack succeeded in stealing session cookies, giving the attacker read access to the users table.

○ C. The HTTP 500 errors indicate a denial-of-service attack; the database queries were generated by an unrelated internal maintenance process.

● D. A SQL injection attack was successfully executed, resulting in authentication bypass and data exfiltration from the users table.

Correct answer: D

Why: The three evidence streams form a coherent, sequential attack narrative. Single-quote characters triggering HTTP 500 errors reveal that the application passes unsanitized input to the database (LO 5.6.A/E). The `OR '1'='1'` pattern in database audit logs is a canonical tautology-based authentication bypass payload, the attack succeeded (server returned 200 on subsequent requests). The timestamped users table export confirms successful data extraction within the incident window. Together these constitute a SQL injection → authentication bypass → data exfiltration chain.

*Why the others are wrong: **A**, A routine connectivity failure does not produce structured tautological WHERE clauses in database audit logs or result in a table export; the patterned nature of the queries rules out random failure. **B**, XSS is a client-side attack injecting scripts into HTML responses to be executed in a victim's browser; it does not produce `OR '1'='1'` payloads in database-layer query logs. XSS and SQLi operate at entirely different layers of the stack. **C**, DoS attacks are characterized by high-volume undifferentiated requests; the structured, low-volume injection payloads are inconsistent with DoS behavior. Internal maintenance processes do not generate tautological SQL WHERE clauses.*

18. An organization's AI-powered anomaly detection system fails to alert on a sophisticated attacker who spent three months studying the organization's normal application behavior before acting, then deliberately constrained their malicious activity to remain within the established behavioral baseline. Which limitation of AI-assisted detection does this scenario MOST directly illustrate?

○ A. AI detection systems process log data more slowly than human analysts, creating a detection lag.

○ B. AI detection systems require explicit human approval before classifying any event as malicious.

● C. AI behavioral models can be evaded by adversaries who perform reconnaissance to understand and then mimic the established baseline pattern.

○ D. Anomaly detection is fundamentally ineffective against all cyberattacks and should be fully replaced with signature-based detection.

Correct answer: C

Why: This scenario illustrates a documented advanced persistent threat (APT) evasion technique sometimes described as "living within the baseline" or low-and-slow evasion. Because the attacker modeled normal behavior before acting, their malicious activity is statistically indistinguishable from noise within the trained model's normal distribution. The model cannot alert on what it has learned to treat as normal. Defense-in-depth, layering behavioral analytics with signature detection, threat intelligence feeds, and human threat hunting, mitigates this single-point-of-failure limitation.

*Why the others are wrong: **A**, AI systems typically process log data orders of magnitude faster than human analysts; processing speed is not the limitation illustrated by this scenario. **B**, Human-in-the-loop approval is one workflow architecture for AI detection, not a universal limitation; many AI detection systems operate autonomously. More importantly, this is not what the scenario illustrates. **D**, Anomaly detection successfully surfaces many attack classes; the correct engineering response to its limitations is layered complementary controls, not wholesale replacement, which would introduce different blind spots.*